



Notes

1.Alert Priority Levels

Introduction

In a Security Operations Center (SOC), thousands of alerts are generated daily. Alert prioritization helps analysts identify which threats need immediate attention.

Priority Definitions:

SOC teams generally use four priority levels:

Priority Level	Description	Example
Critical	Immediate threat causing major damage or active attack	Ransomware encrypting files
High	Serious security issue needing urgent response	Unauthorized admin login
Medium	Suspicious activity with moderate impact	Multiple failed login attempts
Low	Minor or informational alerts	Antivirus update notification

1.Critical Alert

A critical alert indicates a severe security incident that can heavily impact the organization.

Examples

- Ransomware attack
- Domain admin compromise
- Database breach

Response Time

Immediate action required.

2. High Alert

A high alert represents a dangerous activity that may become critical if ignored.

Examples

- Unauthorized admin access
- Brute force attack
- Remote code execution attempt

3.Medium Alert



A medium alert indicates suspicious or unusual activity with limited impact.

Examples

- Repeated failed logins
- Suspicious PowerShell execution
- Unusual outbound traffic

4. Low Alert

Low alerts are informational or low-risk activities.

Examples

- User password reset
- Antivirus scan completed
- Normal port scan inside lab

Factors Used for Alert Prioritization

1.Asset Criticality

The importance of the affected system.

Asset Type	Priority Impact
Production Server	High
Domain Controller	Critical
Test VM	Low
Employee Laptop	Medium

2.Exploit Likelihood

Probability that attackers can exploit the vulnerability.

Example:

Log4Shell had public exploits available, so exploit likelihood was very high.

3. Business Impact

Measures damage to organization operations.

Example:

Attack on banking payment system = Critical business impact.



CVSS (Common Vulnerability Scoring System)

CVSS is an industry standard used to measure vulnerability severity.
Developed by FIRST (Forum of Incident Response and Security Teams).

Score	Severity
0.0	None
0.1 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10.0	Critical

CVSS Metrics

1. Base Metrics

Measures core characteristics of vulnerability.

Includes:

- Attack Vector
- Attack Complexity
- Privileges Required

2. Temporal Metrics

Measures factors changing over time.

Includes:

- Exploit availability
- Patch availability
- Report confidence

3. Environmental Metrics

Measures impact in specific organization environment.

Includes:

- Asset importance
- Security controls
- Business requirements

Log4Shell Example (CVE-2021-44228)

Overview

Log4Shell was a critical vulnerability in Apache Log4j.

CVSS Score



9.8 (Critical)

Why Critical?

- Remote code execution
- Public exploit available
- Affected many organizations

2. Incident Classification

A. Incident Categories

Security incidents are classified based on attack type and impact.

- **Malware** – Viruses, ransomware, spyware infections
- **Phishing** – Fake emails/websites used to steal credentials
- **DDoS** – Flooding a server/network to make services unavailable
- **Insider Threat** – Unauthorized actions by employees or trusted users
- **Data Exfiltration** – Stealing sensitive data from systems

Example:

Employee copies company files to personal USB → *Insider Threat*

B. Taxonomy Frameworks

Standard frameworks help analysts label incidents consistently.

- MITRE ATT&CK
Maps attacker tactics and techniques
Example: **T1566 – Phishing**
- ENISA Incident Taxonomy
Provides structured incident classification categories
- VERIS
Used for recording and sharing incident details

C. Contextual Metadata

Additional information added to incidents for better investigation.

- Affected systems
- Date and time of attack
- Source IP address



- Indicators of Compromise (IOCs)
 - Malicious file hash
 - Suspicious domain
 - Attack URL

3. Basic Incident Response

A. Incident Response Lifecycle

Preparation: This phase focuses on getting ready before an incident happens.

Activities:

Create IR policies and playbooks

Train security teams

Install security tools (SIEM, EDR, Antivirus)

Identification: Detect and confirm whether a security incident has occurred.

Activities:

- Monitor alerts and logs
- Perform alert triage
- Analyze suspicious activity

Containment: Stop the attack from spreading.

Activities:

- Isolate infected systems
- Disable compromised accounts
- Block malicious IPs/domains

Eradication: Remove the root cause of the attack.

Activities:

- Delete malware
- Remove malicious files
- Patch vulnerabilities

Recovery



Restore systems and services safely.

Activities:

- Restore backups
- Monitor systems for reinfection
- Return systems to production

Important Incident Response Procedures

1.System Isolation

Separating infected devices from the network to stop spread.

2. Evidence Preservation

Collecting and protecting evidence for investigation.

Methods:

- Memory dumps
- Log collection
- File hashing

3.Communication Protocols

Proper communication during incidents.

Includes:

- Informing management
- Reporting to SOC team
- Escalation procedures

4.SOAR (Security Orchestration, Automation, and Response)

Tools that automate incident response tasks.

Functions:

- Automate alert handling
- Create workflows
- Reduce manual work



CYART

inquiry@cyart.io

www.cyart.io